



Test Case Catalogue — TASCO Growth Platform

TASCO Insurance × VETC Growth Platform — Quality Engineering

iorta TechNXT

Version 1.0 · 07 October 2026

Prepared by iorta TechNXT for TASCO Insurance. Confidential: for the use of TASCO Insurance and VETC only.

Contents

How to read this catalogue

1. Authentication and session
2. Authorisation (RBAC / ABAC)
3. Customer 360, data enrichment and MDM
4. Lead scoring, NBA and benefits
5. Journeys and contact compliance
6. Voice bot and telesales handoff
7. Quote → pay → issue → e-certificate
8. Partners and partner API
9. Rules engine and maker-checker
10. Claims FNOL
11. Privacy, encryption and audit
12. Operations, jobs and events
13. HTTP pipeline and platform security
14. Non-functional, resilience and DR
15. Accessibility and localisation
16. SIT with VETC, TASCO and Zalo
17. Additional cases (assisted sales and review findings)
18. Traceability summary

Document	Version	Date	Owner	Status
Test Case Catalogue	1.0	07 October 2026	iorta TechNXT QA Lead	Issued for submission

Item	Value
Baseline	G2 (build complete) and G3 (go/no-go)
Strategy	Test Strategy (levels, environments, severity, known issues KI-xx in Appendix A)
Cases	164 (TC-001 – TC-164), plus TC-080a
Record of execution	TASCO-Test-Cases-and-Results.xlsx (docs/quality/TASCO-Test-Cases-and-Results.xlsx), sheet <i>Test Cases</i> (one row per TC with actual result and status) and <i>Automated Run</i> (one row per automated test)
Functional scenarios	The 124 user-story scenarios automated in <code>test/functional</code> are catalogued separately in the workbook sheet <i>Functional Test Cases</i>

How to read this catalogue

- **Type:** `Unit`, `Int` (integration via `createContainer` + in-memory store), `API` (HTTP against `createHttpApp`), `Sec` (security/abuse, `test/security`), `PG` (needs Postgres, `test/pg`), `SIT`, `UAT`, `NFT`.
- **Pri:** P1 (must pass for any release), P2 (must pass for go-live), P3 (should pass).
- **Automation:** the suite file that hosts the case, or **Manual**. The automated suites are `test/unit/{identity,jsonLogic,platform,rulesDomain,stores,voicebot}.test.js`, `test/integration/{journeys,sales,governance}.test.js`, `test/api/api.test.js`, `test/security/security.test.js`, `test/functional/*.test.js`, `test/pg/postgres.test.js` (PostgreSQL) and `test/perf/load.js`. The QA Lead confirms at each release that every automated case is asserted in its file.
Where a case is still blocked by an open known issue, the expected result describes the *correct* behaviour and the case is tagged with the KI ID.
- **Preconditions** use the demo users from `src/bootstrap/seed.js` (for example `admin`, `agent.hn`, `author`, `approver`) in LOCAL, DEV and the hosted UAT (`DEMO_MODE=true`). All of them share the demo password of their environment, and `admin`, `approver`, `compliance` and `steward` need TOTP. Times are ICT (UTC+7) unless stated.
- Every API error has the body `{ error: { code, message, details?, requestId } }`. Expected results quote the `code`.

Index by module

Module	IDs
Authentication and session	TC-001 – TC-020
Authorisation (RBAC / ABAC)	TC-021 – TC-030
Customer 360, data enrichment and MDM	TC-031 – TC-040
Lead scoring, NBA and benefits	TC-041 – TC-049
Journeys and contact compliance	TC-050 – TC-063
Voice bot and telesales handoff	TC-064 – TC-070
Quote → pay → issue → e-certificate	TC-071 – TC-080
Partners and partner API	TC-081 – TC-089
Rules engine and maker-checker	TC-090 – TC-099
Claims FNOL	TC-100 – TC-104
Privacy, encryption and audit	TC-105 – TC-111

Module	IDs
Operations, jobs and events	TC-112 – TC-116
HTTP pipeline and platform security	TC-117 – TC-135
Non-functional, resilience and DR	TC-136 – TC-143
Accessibility and localisation	TC-144 – TC-149
SIT with VETC, TASCO and Zalo	TC-150 – TC-155
Additional cases (assisted sales, review findings)	TC-156 – TC-164
Traceability summary	—

1. Authentication and session

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-001	Password login for a role without MFA	Demo seed; user exec	POST /api/auth/login {username:"exec", password:<demo>}	200; accessToken, expiresIn=1800, user.permissions contains dashboard:read; audit auth.login	API	P1	test/api/api.test.js
TC-002	MFA challenge for an MFA-required role	User admin (TOTP enrolled)	Login with the correct password	200 {mfaRequired:true, mfaToken}; no accessToken	API	P1	test/api/api.test.js
TC-003	Complete MFA with a valid TOTP	TC-002 done	POST /api/auth/mfa {mfaToken, code:totp(secret)}	200; token claims amr:["pwd","otp"], aud:"staff"; failedLogins reset to 0	API	P1	test/api/api.test.js
TC-004	Wrong password is rejected without detail	User exec	Login with a wrong password	401 UNAUTHENTICATED "Invalid username or password"; audit auth.login_failed reason bad_password; failedLogins=1	API	P1	test/api/api.test.js
TC-005	Lockout after 5 failures	User exec; LOCKOUT_MAX_FAILURES=5	5 wrong passwords, then the correct password	Attempts 1–5 → 401; attempt 6 → 423 ACCOUNT_LOCKED; audit auth.login_locked	Sec	P1	test/security/security.test.js
TC-006	Lock expires after LOCKOUT_MINUTES	TC-005; clock advanced 15 min (or LOCKOUT_MINUTES=0 in test config)	Correct login	200; failedLogins=0, lockedUntil=null	Sec	P2	test/security/security.test.js
TC-007	No username enumeration	—	Login with an unknown user, then a known user with a wrong password; compare	Same 401 message; response times within ±30 % (the timing equaliser hashes a dummy password); audit actor anonymous	Sec	P2	test/security/security.test.js
TC-008	MFA wrong code	TC-002	POST /api/auth/mfa with code 000000 (or any wrong 6 digits)	401 "Invalid code"; audit auth.mfa_failed; failedLogins incremented	Sec	P1	test/security/security.test.js
TC-009	MFA token expiry	TC-002; clock +301 s	Submit a valid code	401 "MFA session expired — sign in again"	API	P2	test/api/api.test.js
TC-010	MFA self-enrolment for an MFA-required role	Admin creates a user with role rule_approver (the seed is never shown to the admin; mustChangePassword:true)	Login; scan otpauthUri; POST /api/auth/mfa with a valid code; change password	Login → {mfaRequired:true, mfaEnrolment:true, otpauthUri}; first valid code completes enrolment (audit auth.mfa_enrolled) and returns mustChangePassword:true; next logins challenge without otpauthUri	API	P1	test/api/api.test.js
TC-011	Disabled user is cut off immediately	agent.hn holds a valid token	Admin PATCH /api/users/:id {status:"disabled"}; agent calls GET /api/auth/me; agent logs in again	me → 401 (status checked on every request; status/role/region changes also invalidate earlier tokens via tokensValidAfter); login → 401 reason inactive	API	P1	test/api/api.test.js

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-012	Demo TOTP helper absent outside demo mode	DEMO_MODE=false	GET /api/demo/totp/admin	404 NOT_FOUND "Endpoint not found"	Sec	P1	test/security/security.test.js
TC-013	JWT alg: none is rejected	Valid token	Re-encode the header {"alg": "none"} with an empty signature; call GET /api/auth/me	401	Sec	P1	test/security/security.test.js
TC-014	Tampered JWT (privilege escalation)	exec token	Change the payload roles: ["admin"] and keep the signature	401 (HMAC mismatch); also the server reads roles from the user record, not the token	Sec	P1	test/security/security.test.js
TC-015	Expired token	Token with exp in the past (sign with a negative TTL in the test)	GET /api/auth/me	401	Sec	P1	test/security/security.test.js
TC-016	Token audience confusion	mfaToken from TC-002; customer token from POST /api/customer/session	Use the mfaToken as a bearer on a staff route; use the customer token on GET /api/leads	401 for the mfaToken (aud: "mfa" rejected); 403 "Staff token required" for the customer token	Sec	P1	test/security/security.test.js
TC-017	Logout revokes the token	Logged-in exec	POST /api/auth/logout, then GET /api/auth/me with the same token	401 on the same replica. <i>Note KI-07: per replica only.</i>	API	P2	test/api/api.test.js
TC-018	Password policy and change	exec token	POST /api/auth/password with new password short; then with a wrong current password; then valid	400 "Password policy" (≥ 12 chars; must differ from the current one); 401 "Current password is incorrect"; 200 {reauthenticate:true} + audit.auth.password_changed; the old token is rejected afterwards	API	P2	test/api/api.test.js
TC-019	/api/auth/me reflects the RBAC mapping	Each demo user	GET /api/auth/me	permissions equals the union of rbac.json for the user's roles	API	P2	test/api/api.test.js
TC-020	MFA step honours lockout (KI-06)	admin locked (5 failures) but holding an unexpired mfaToken	POST /api/auth/mfa with a correct code	423 ACCOUNT_LOCKED; a replayed (already used) code → 401 "Invalid code" (KI-06 fixed)	Sec	P2	test/security/security.test.js

2. Authorisation (RBAC / ABAC)

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-021	Full route × role authorisation matrix	Tokens for all 13 staff roles + customer + partner	Call every route in the route table (80) with each principal (minimal valid body)	Route perm $\notin$ role permissions → 403 FORBIDDEN "Missing permission ..."; no token → 401; public routes reachable without a token	API	P1	test/api/api.test.js
TC-022	Segregation of duties for admin	admin token	GET /api/customers/:id; POST /api/rules; POST /api/rules/:id/approve	403 for all (admin has no profile:read, rules:author or rules:approve)	API	P1	test/api/api.test.js
TC-023	Regional lead queue for agents	agent.hn (region Hà Nội)	GET /api/leads?region=TP.%20H%E1%BB%93%20Ch%C3%AD%20Minh	Every item has region:"Hà Nội": the query region is overridden for users without dashboard:read	API	P1	test/api/api.test.js
TC-024	ABAC region on Customer 360	agent.hn; profile in TP.HCM	GET /api/customers/<hcm-id>	403 "Policy regional_data denies read on this profile"	Sec	P1	test/security/security.test.js
TC-025	Agents see only their own or unassigned handoffs	Handoff assigned to agent.hcm	agent.hn: GET /api/handoffs/:id; PATCH it	403 (agent_own_handoffs); the list endpoint omits it	Sec	P1	test/security/security.test.js
TC-026	Assignment requires supervisor	Open handoff	agent.hn PATCH {assignTo:"U-x"}; supervisor the same	Agent → 403 "Missing permission handoff:assign"; supervisor → 200, audit handoff.updated	API	P1	test/api/api.test.js
TC-027	No self-administration; separation of duties	admin token	PATCH /api/users/<self> {roles:["executive"]}; POST /api/users with roles ["rule_author", "rule_approver"]	422 "You cannot change your own roles or status"; 422 "Separation of duties: rule_author and rule_approver cannot be held by the same person"	API	P2	test/api/api.test.js
TC-028	Unknown role rejected	admin	POST /api/users with roles: ["superuser"]	400 "Unknown role superuser"	API	P2	test/api/api.test.js
TC-029	Region restriction beyond Customer 360 (KI-10)	agent.hn; HCM profile	GET /api/customers/<hcm-id>/lineage; POST /api/voice/sessions {profileId:<hcm-id>}; GET /api/policies?profileId=<hcm-id>	Lineage → 403 (enforced). Expected for voice sessions and policies: 403. <i>Currently 200: KI-10 open</i>	Sec	P2	test/security/security.test.js (lineage); rest blocked by KI-10
TC-030	Audience separation	Staff token, customer token	Staff token on GET /api/customer/home; customer token on GET /api/policies	403 "Customer token required"; 403 "Staff token required"	Sec	P1	test/security/security.test.js

3. Customer 360, data enrichment and MDM

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-031	PII masking by permission	campaign (no profile:read_pii), agent.hn (has it)	GET /api/customers/:id as each	Campaign: name/phone masked, piiMasked:true, message to omitted; agent: clear values. Audit profile.viewed with piiVisible false/true	API	P1	test/api/api.test.js
TC-032	Plate and phone normalisation on ingest	steward token	POST /api/data/ingest with plates 30a-123.45, 30A 12345, 30A.123.45, 30-12345 and phones +84912345678, 912345678, 0912 345 678	The first three plates map to key 30A12345; 30-12345 rejected with DQ invalid_plate; phones normalise to 0912345678; response rejected=1	Int	P1	test/unit/identity.test.js, test/integration/journeys.test.js
TC-033	Survivorship across sources	Same plate in vetc_account (trust 0.85) and partner_agent (0.5) with different names	Ingest both	Golden profile takes the higher-trust attribute; lineage lists both record IDs and sources	Int	P1	test/integration/journeys.test.js
TC-034	Conflicting phones raise a DQ issue	Two sources, same plate, different valid phones	Ingest	DQ issue <plate>:conflicting_phone open	Int	P2	test/integration/journeys.test.js
TC-035	Customer-declared expiry survives rebuild	Customer declared expiry (confidence 0.8)	Re-ingest an older partner record for the plate (lower confidence)	Profile keeps expiryMethod:"customer_declared" and its date	Int	P1	test/integration/journeys.test.js
TC-036	Erased profiles are not re-identified	Profile anonymised (TC-107)	Ingest a new source record with name and phone for the same plate	Profile stays anonymised:true with null name and phone	Int	P1	test/integration/governance.test.js
TC-037	Data steward expiry correction	steward (MFA)	PATCH /api/customers/:id/expiry {expiryDate, insurer, evidence:"Cert scan #123"}; then without evidence	200; audit profile.expiry_corrected with evidence; lead recomputed; confidence 0.9 (service_levels); no evidence → 400; regional stewards limited by ABAC regional_data	API	P1	test/api/api.test.js
TC-038	DQ issue lifecycle	Open invalid_plate issue	POST /api/dq/issues/:id/resolve {resolution}; re-ingest the same bad record	Status resolved with resolvedBy; the re-ingest reopens it (a resolved issue is re-raised when detected again)	API	P2	test/api/api.test.js
TC-039	Ingest input allow-list and bounds	steward	Batch of 5,001 records; batch with an extra field isAdmin:true; record without recordId	400 "at most 5000 items"; extra field stripped (not stored); 400 records[i].recordId required	API	P2	test/api/api.test.js
TC-040	Lineage view	Profile built from 2 sources	GET /api/customers/:id/lineage	fields[] contains policy.expiryDate source and confidence; sourceRecords lists record IDs; recentBatches ≤ 10	API	P3	test/api/api.test.js

4. Lead scoring, NBA and benefits

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-041	Benefits pending legal review never reach customers	benefits.json has loyalty_points pending_legal_review and an eligible profile	GET /api/customer/home; GET /api/customers/:id (staff)	Customer benefits[] excludes loyalty_points and available:false items (auto_renew, fleet_dashboard), at most 3 shown; staff view shows them flagged (legalStatus, available)	API	P1	test/api/api.test.js
TC-042	Explainable score and tiers	Fixed profile facts	evaluateLead	score = round($\sum \text{weight} \times \text{value} \times (0.6 + 0.4 \times \text{expiryConfidence})$); tier hot ≥ 70 , warm ≥ 45 , else nurture; reasons[] sorted by points with why text	Unit	P1	test/unit/rulesDomain.test.js
TC-043	Fix data before selling	Profile with expiryConfidence < 0.5	Recompute	NBA verify_expiry (rule fix_data)	Unit	P1	test/unit/rulesDomain.test.js
TC-044	DNC suppresses everything	Profile consent.dnc:true	Recompute	NBA suppress; no touchpoints planned	Int	P1	test/integration/journeys.test.js
TC-045	Company vehicles routed to B2B	ownerType:"company"	Recompute	NBA route_b2b; excluded from /api/voice/campaign	Unit	P2	test/unit/rulesDomain.test.js
TC-046	TASCO-insured vehicles leave journeys	Active TASCO TNDS policy ending after today	Recompute	journey:null, NBA insured; existing scheduled touchpoints deleted	Int	P1	test/integration/journeys.test.js
TC-047	Journey priority order	Profile lapsed 10 days, confidence ≥ 0.5	assignJourney	lapsed_uninsured (priority 1) chosen over renewal and conquest	Unit	P2	test/unit/rulesDomain.test.js
TC-048	Touchpoints re-planned only on change	Lead recomputed twice with no change	Count touchpoints	No duplicates (ids profile:journey:step:date); a tier change deletes and re-plans the scheduled ones	Int	P2	test/integration/journeys.test.js
TC-049	Lead queue filters and bounds	campaign	GET /api/leads? tier=hot&minScore=70&sort=expiry&limit=500; limit=501; tier=cold	200 filtered and sorted; 400 for limit > 500; 400 enum violation	API	P2	test/api/api.test.js

5. Journeys and contact compliance

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-050	No marketing before 08:00 ICT; blocked touchpoints deferred	Due marketing touchpoint (e.g. <code>renewal/first_reminder</code>); consent OK; <code>DEMO_MODE=true</code> (test clock)	<code>runDue</code> with <code>at = <date>T00:59:00Z (07:59 ICT)</code> ; then a run at 03:00Z	First run: no message, touchpoint stays <code>scheduled</code> , counted as <code>deferred</code> (reason "outside allowed contact hours"); second run: <code>done</code> (KI-05 fixed)	Int	P1	<code>test/unit/rulesDomain.test.js</code> , <code>test/integration/journeys.test.js</code>
TC-051	Window boundaries inclusive at start	As TC-050	Run at 01:00Z (08:00 ICT) and 12:59Z (19:59 ICT)	Sent (<code>done</code>) both times (on separate profiles to avoid caps)	Unit	P1	<code>test/unit/rulesDomain.test.js</code>
TC-052	No marketing at or after 20:00 ICT	As TC-050	Run at 13:00Z (20:00 ICT)	Blocked, "outside allowed contact hours"	Unit	P1	<code>test/unit/rulesDomain.test.js</code>
TC-053	Marketing needs marketing consent	<code>consent.marketing:false</code>	<code>canContact(..., {marketing:true})</code>	Reason "no marketing consent"	Unit	P1	<code>test/unit/rulesDomain.test.js</code>
TC-054	Calls need call consent	<code>consent.call:false</code>	<code>canContact</code> for <code>voice_bot</code> and <code>telesales</code>	Reason "no call consent"	Unit	P1	<code>test/unit/rulesDomain.test.js</code>
TC-055	DNC customer is never contacted	<code>consent.dnc:true</code>	Service (<code>marketing:false</code>) and marketing on every channel; <code>POST /api/voice/sessions</code>	Every channel blocked "customer is on do-not-contact list"; voice session start → 422 "Customer is on the do-not-contact list"	Int	P1	<code>test/unit/rulesDomain.test.js</code> , <code>test/api/api.test.js</code>
TC-056	Daily marketing cap (1/day)	One marketing message sent in the last 24 h	Next marketing touchpoint	Blocked "daily contact cap reached"	Unit	P1	<code>test/unit/rulesDomain.test.js</code>
TC-057	Weekly caps (3 marketing, 2 calls)	3 marketing messages in 7 days; separately 2 voice/telesales contacts	Next marketing / next call	"weekly contact cap reached" / "weekly call cap reached"	Unit	P1	<code>test/unit/rulesDomain.test.js</code>
TC-058	Service messages bypass caps and window	Caps reached; 22:00 ICT; <code>serviceMessagesBypassCaps:true</code>	<code>lapsed_notice</code> (<code>marketing:false</code>)	Allowed (consent and DNC still apply)	Unit	P2	<code>test/unit/rulesDomain.test.js</code>

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-059	Touchpoint cancellation rules	Scheduled touchpoint; then the customer buys TASCO TNDS / the lead's journey changes	Run due	cancelled, reason "already insured with TASCO" / "journey changed to ..."	Int	P1	test/integration/journeys.test.js
TC-060	Runtime copy guard blocks banned wording	Test-only active template containing "giảm giá" (inserted directly in the store, bypassing validation)	Run due	Message stored status:"blocked", blockReason "copy guard: giảm giá"; nothing sent to the gateway; messages_total{status="blocked"} +1	Int	P1	test/integration/journeys.test.js
TC-061	Copy guard ignores diacritics, case, spacing and punctuation	Banned list as shipped	checkCopy on "GIAM GIA", "Giảm Giá", "Cashback", "cash back", "giảm giá" (double space), "c.a.s.h-back"	All blocked (KI-26 fixed); "Gia hạn bảo hiểm" allowed	Unit	P1	test/unit/rulesDomain.test.js, test/integration/sales.test.js
TC-062	Channel fallback and failure accounting	Zalo gateway port throws	Touchpoint with channels [zalo_zns, sms]	Zalo message failed; SMS sent; touchpoint done with channel:"sms"; messages_total{channel="zalo_zns",status="failed"} +1	Int	P2	test/integration/journeys.test.js
TC-063	Ecosystem moments of truth	Profile with days < 60	POST /api/ecosystem/events {type:"vetc.inspection_booked"}; {type:"vetc.tag_activated"}	Inspection → inspection_tnds_check message via app_push/zalo (service); tag → lead.recompute_requested published; audit ecosystem.event_handled	API	P2	test/api/api.test.js

6. Voice bot and telesales handoff

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-064	Disclosure and plate privacy	Profile with plate 30A-123.45	POST /api/voice/sessions	First bot line is intro (automated assistant, never asks for OTP or payment); no bot line contains the full plate (only the masked 30A-***.45 if any)	API	P1	test/unit/voicebot.test.js, test/api/api.test.js
TC-065	Plate verification from speech	Session in verify_plate for 30A12345	Turns "ba không A một hai ba bốn năm", "30A 123 45", "biển số 30A-123.45", and the plateRetry example "ba mươi A, một hai ba bốn năm"	Each → verified:true, state confirm_expiry; tens words and motorbike plates parse (KI-25 fixed)	Unit	P1	test/unit/voicebot.test.js, test/unit/identity.test.js

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-066	Plate mismatch ends the call and raises DQ	Session for 30A12345	Turn "29A 999 99"	Outcome plate_mismatch; DQ issue <id>:plate_mismatch open; no expiry or premium disclosed	Int	P1	test/integration/governance.test.js
TC-067	Unverifiable caller	maxPlateAttempts=3	Three turns with no plate	Outcome unverified; no personal data spoken	Unit	P2	test/unit/voicebot.test.js
TC-068	Opt-out via voice bot is honoured	Profile with call consent	Turn "đừng gọi nữa"	Outcome opted_out; profile consent.call:false, dnc:true (also in consentOverrides, so it survives rebuilds); audit consent.withdrawn; lead NBA becomes suppress; later /api/voice/campaign skips the profile	Int	P1	test/integration/governance.test.js
TC-069	Scam concern handled with the trust script	Session	Turn "lừa đảo à"	trust line spoken; signals.trustConcern:true; the handoff talking points instruct "never take payment by phone"	Unit	P2	test/unit/voicebot.test.js
TC-070	Hot lead handoff summary is minimal	Verified session	Turn "tôi muốn mua ngay"	Outcome hot_handoff; handoff H0-... with phoneMasked (no full phone), plateVerifiedByCustomer:true, talking points; event handoff.created; voice_calls_total{outcome="hot_handoff"} +1	Int	P1	test/integration/governance.test.js

7. Quote → pay → issue → e-certificate

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-071	IDOR: customer cannot buy another customer's quote	Customer A and B sessions; quote Q-B for B	A: POST /api/customer/orders {quoteId:Q-B} with an Idempotency-Key	404 NOT_FOUND "Quote not found" (no existence disclosure); no debit	Sec	P1	test/security/security.test.js
TC-072	Regulated TNDS premium is exact	tariff.tnds_car car_under6 437,000 VND, VAT 10 %	POST /api/customer/quotes {products: [{code:"TNDS_CAR"}]} for a 1-year term starting the day after expiry	premiumNet = 437,000 × termYears (whole-year terms; no leap-day pro-rata), vat = round(net × 0.1) = 43,700, total = 480,700 for 1 year; priceRegulated:true; no discount field	Unit / API	P1	test/unit/rulesDomain.test.js, test/api/api.test.js
TC-073	Idempotent double purchase	Open quote	Two sequential POST /api/customer/orders with the same Idempotency-Key	First 200 idempotentReplay:false; second 200 idempotentReplay:true, same order id; exactly one wallet debit; one orders_completed_total increment	API	P1	test/api/api.test.js

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-074	Public certificate verification discloses no PII	Issued policy	GET /api/public/certificates/<certNo>; unknown certNo	valid:true, state:"in_force", masked plate (30A-***.45), product, dates, insurer; no name or phone. Early renewal → not_yet_in_force; lapsed → expired; unknown → reason:"not_found"	API	P1	test/api/api.test.js
TC-075	Quote expiry (service_levels.quoteTtlHours = 24)	Quote created; clock +24 h 1 min	Purchase	422 BUSINESS_RULE_VIOLATION "Quote expired — please re-quote"; no order	API	P1	test/api/api.test.js
TC-076	Converted quote cannot be re-bought with a new key	TC-073 done	Purchase the same quote with a different key	422 "Quote is converted"	API	P1	test/api/api.test.js
TC-077	Channel eligibility	Product whose channels exclude partner_api (test catalogue)	Partner quote for it	422 "... is not sold on channel partner_api"	Unit	P2	test/integration/sales.test.js
TC-078	Physical damage underwriting limits	rating.motor_pd maxSumInsured 5,000,000,000	Quote MOTOR_PD sumInsured 6e9; deductible 250,000	422 "Sum insured exceeds the online limit — refer to underwriter"; 400 "Unsupported deductible"	Unit	P2	test/unit/rulesDomain.test.js
TC-079	Wallet outage	Wallet port throws errors.upstream	Customer purchase × 6	503 UPSTREAM_UNAVAILABLE; order payment_failed; audit order.payment_failed; after 5 failures vetc-wallet opens: next call short-circuits (integration_short_circuit_total +1); /api/ops/status shows open	Int	P1	test/integration/sales.test.js
TC-080	Issuance failure compensation (saga)	Policy admin port fails on line 2 of a TND5 + PA_SEAT quote	Customer purchase; then retry with the same key and with a new key	Line 1 policy cancelled; full refund via the vetc-wallet breaker; order issuance_failed_refunded (compensation_failed if a cancel or refund fails); audit order.issuance_failed; quote released; same key → 409; new key → completed (KI-02 fixed)	Int	P1	test/integration/sales.test.js

Additional sales case: **TC-080a** (kept under TC-080's ID family for traceability). Two **concurrent** purchases of the same quote. Expected: one order and one debit, because the quote is claimed atomically (`paying`); the second request gets 409 `CONFLICT` ("This quote is already being paid", or KI-20 for the same key). Automated in `test/security/security.test.js` ("concurrent purchases of one quote cannot double-charge").

8. Partners and partner API

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-081	IDOR: partner cannot bind another partner's quote	Keys for P-BANK-01 and P-SHOWROOM-01; quote by BANK	SHOWROOM POST /api/partner/v1/orders {quoteId}	404 "Quote not found"; no debit	Sec	P1	test/security/security.test.js
TC-082	Partner key authentication	—	No X-API-Key; key without the tpk_ prefix; key > 100 chars; revoked key; key of a suspended partner	401 "Valid X-API-Key required" in every case	Sec	P1	test/security/security.test.js
TC-083	Unknown plate onboarding (new business)	Plate not in the base	POST /api/partner/v1/quotes {plate:"516-678.90", holderName, phone, currentExpiry}; invalid plate ABC; invalid phone 123	Profile created from source partner_<type> with lineage; quote with channel:"partner_api", partnerId; ABC → 400 "Invalid licence plate"; bad phone → 400	API	P1	test/api/api.test.js
TC-084	Commission above statutory cap is rejected	author	POST /api/rules {kind:"commission", payload:<tnds rule rate 0.08>}	400 "rule tnds_any: rate 0.08 exceeds statutory cap 0.05 for TND\$_CAR"	API	P1	test/api/api.test.js
TC-085	Runtime commission and statement	Partner order: TND\$ + MOTOR_PD (showroom)	GET /api/partner/v1/statement?from=&to=	Lines: TND\$ 5 %, PD 10 %; capped:false; totalCommission = Σ amounts; only the partner's own completed orders	API	P1	test/api/api.test.js
TC-086	API key shown once, stored hashed	partners (partner manager)	POST /api/partners/:id/keys; read the api_keys row	Response contains apiKey tpk_... once; the stored row has keyHash (SHA-256) and prefix only; audit partner.api_key_issued with keyId and prefix	API	P1	test/api/api.test.js
TC-087	Partner sees only its own policies	Two partners with sales	GET /api/partner/v1/policies	Only partnerId = caller	Sec	P1	test/security/security.test.js
TC-088	Statement date filter	Orders on 3 dates	?from=D2&to=D2; from=2026-13-01	Only D2 orders; 400 for an invalid date	API	P3	test/api/api.test.js
TC-089	Key revocation is immediate	Active key	DELETE /api/partners/keys/:keyId, then a partner call	200 {revoked:true}; the next call → 401; audit partner.api_key_revoked	API	P1	test/api/api.test.js

9. Rules engine and maker-checker

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-090	Maker cannot approve own rule	SoD stops one person holding both roles through the API (TC-027), so the test inserts a dual-role user directly into the store, then creates and submits a draft	POST /api/rules/:id/approve by the same user	403 "Maker-checker: you cannot approve your own change"	Sec	P1	test/security/security.test.js
TC-091	Maker cannot reject own rule	As TC-090	POST /api/rules/:id/reject	403 "Maker-checker: you cannot review your own change"	Sec	P1	test/security/security.test.js
TC-092	Submission rules	Draft by author	Another author submits; author submits twice	403 "Only the author can submit a draft"; second → 422 "Only drafts can be submitted (status: pending_approval)"	API	P1	test/api/api.test.js
TC-093	Approval activates and retires	Pending scoring@2 by author	approver (MFA) approves	scoring@2 active, scoring@1 retired with supersededBy; audit rules.approved; event rules.activated; GET /api/ops/status rules[] shows version 2 and its checksum	API	P1	test/api/api.test.js
TC-094	Rollback goes through approval	Active scoring@2	POST /api/rules/scoring@1/rollback	New draft scoring@3 with the payload of @1, description "Rollback to scoring@1"; @2 stays active until @3 is approved	API	P1	test/api/api.test.js
TC-095	Banned discount wording in templates is rejected	author	POST /api/rules {kind:"content.messages", payload: <template with "giảm giá 10%>}; same with "Giảm giá"	400 "Rule set is invalid", details contain copy guard: "giảm giá"	API	P1	test/api/api.test.js
TC-096	Scoring payload validation	author	Validate scoring with weights summing to 90; tiers.hot ≤ warm	Errors "factor weights must sum to 100 (got 90)", "tiers.hot must be greater than tiers.warm"	Unit	P2	test/unit/rulesDomain.test.js
TC-097	Simulation without side effects	campaign (rules:read)	POST /api/rules/simulate {profileId, kind:"scoring", payload}	{current, candidate} returned; no ruleset row created; invalid payload → 400 with errors	API	P2	test/api/api.test.js
TC-098	Unknown JSON Logic operator rejected	—	Validate a payload with {"eval": ["..."]} in a when	Validation error (operator not allowed); nothing executed	Unit	P1	test/unit/jsonLogic.test.js
TC-099	Cache convergence across replicas	2 app instances on the same Postgres	Approve on instance A; read on B	B serves the new version within ≤ 15 s (CACHE_TTL_MS)	PG	P2	Manual (PREPROD, two replicas)

10. Claims FNOL

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-100	Customer reports an accident	Active own policy	POST /api/customer/claims {policyId, incidentDate (in period), description, photos:3}	200 CL-... submitted, slaDueAt = now + service_levels.claimAckSlaHours (4 h); event claim.submitted; description and location encrypted at rest	API	P1	test/api/api.test.js
TC-101	IDOR: claim against another customer's policy	B's policy id	A submits FNOL	404 "Policy not found"	Sec	P1	test/security/security.test.js
TC-102	Incident outside cover	—	incidentDate before startDate	422 "Incident date is outside the policy period"	API	P2	test/api/api.test.js
TC-103	Illegal status transition	Claim submitted	claims user PATCH {status:"paid"}	422 "Cannot move claim from submitted to paid"	API	P1	test/api/api.test.js
TC-104	Happy-path lifecycle	Claim submitted	acknowledged → assessor_assigned → under_assessment → approved → paid	Each 200; history[] has 6 entries with actor and note; audit claim.status_changed ×5	API	P2	test/api/api.test.js

11. Privacy, encryption and audit

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-105	DSAR access export	compliance (MFA); customer session	POST /api/dsar/:id/export; customer GET /api/customer/data-export	Profile, lead, policies, messages, source records (internal_hidden stripped) and voice sessions; audit dsar.access_exported	API	P1	test/api/api.test.js
TC-106	Erasure blocked with an active policy	Profile with an active policy	POST /api/dsar/:id/erase	422 "Active policy in force — personal data must be retained until expiry (legal obligation)"; nothing changed	API	P1	test/api/api.test.js
TC-107	Erasure anonymises	Profile with no active policy, messages and voice sessions	Erase	{erased:true}; profile anonymised and DNC; lead deleted; messages, transcripts and voice signals blanked; handoff and claim PII cleared (KI-29 fixed); source PII nulled; sessions revoked; audit dsar.erased	API	P1	test/api/api.test.js
TC-108	PII encrypted at rest	Ingested profile	Read the raw row (memory store) or SELECT data FROM profiles (PG)	name, phone, altPhones stored as enc:v1: <keyId>:...; phone_bidx is an HMAC, not the phone; lookup by blind index works	Unit / PG	P1	test/unit/platform.test.js, test/pg/postgres.test.js
TC-109	Logs redact secrets and PII	Log sink captured	Login, customer 360, partner key issue	No log line contains password, token, apiKey, phone or name values (keys show [REDACTED])	Sec	P1	test/security/security.test.js

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-110	Audit immutability and tamper detection	Postgres with ≥ 10 audit rows	(a) App role: UPDATE, DELETE and TRUNCATE on audit_log; (b) table owner: disable trg_audit_log_immutable, alter row seq=5, re-enable; GET /api/audit/verify	(a) Each statement rejected by the triggers (migrations 001/002); (b) {ok:false, brokenAt:4, reason:"hash mismatch"}	PG	P1	(a) test/pg/postgres.test.js; (b) Manual (DBA)
TC-111	Audit chain stays linear under concurrency	2 app instances	500 parallel audited actions	verify → ok:true, entries = 500 + baseline (advisory lock 724001)	PG	P2	Manual (PERF, two instances)

12. Operations, jobs and events

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-112	Initial data migration reconciles	Source extract of N records (pilot cohort)	Load via the ingest job/API in batches; compare	$\Sigma \text{ records} = N$; $\Sigma \text{ rejected}$ = count of invalid plates in the source; distinct profiles = distinct valid plate keys; 50 random profiles match source fields (masked comparison)	SIT / UAT	P1	Manual (scripted checklist)
TC-113	Reconciliation job finds mismatches	Orders: completed without paymentRef; pending_payment 2 h old; completed with a missing policy; compensation_failed; payment_failed	POST /api/ops/jobs/reconciliation (support)	One mismatch per order: "missing payment reference", "stuck in pending_payment > 1h", "policy ... missing", "compensation failed ... manual action", "payment failed — confirm with VETC wallet" (severity check); job_runs succeeded; audit job.reconciliation	API	P1	test/api/api.test.js
TC-114	Retention job	Source records 400 days old; voice sessions 200 days old	npm run job -- retention / POST /api/ops/jobs/retention	Both deleted; other entities report "executed by archival pipeline" (KI-13); job run recorded	Int	P2	test/integration/governance.test.js
TC-115	Outbox retry then dead letter	Subscriber that always throws	Publish an event; relay × 5	attempts 1..5; status pending until attempt 5, then dead_letter; lastError set; events_processed_total{status="dead_letter"} +1; already-succeeded handlers are not re-run (handled[])	Unit	P1	test/unit/stores.test.js
TC-116	Graceful shutdown	Server under light load	Send SIGTERM	/health/ready → 503 not_ready immediately; in-flight requests complete; the process exits 0 within 25 s (forced exit 1 at 25 s)	NFT	P2	Manual (Kubernetes drill)

13. HTTP pipeline and platform security

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-117	Unknown body properties rejected	Any token	POST /api/quotes with an extra discount: 10	400 VALIDATION_FAILED, details "discount is not allowed"	API	P1	test/api/api.test.js
TC-118	Oversized body	—	POST 1 MiB + 1 byte to /api/auth/login	413 PAYLOAD_TOO_LARGE; connection closed	Sec	P1	test/security/security.test.js
TC-119	Wrong content type	—	POST username=x as text/plain to /api/auth/login	415 UNSUPPORTED_MEDIA_TYPE	Sec	P1	test/security/security.test.js
TC-120	Path traversal on static files	—	GET ../../etc/passwd, GET ../../%2f..%2fpackage.json, GET /assets/../../%2f..%2fsrc/server.js	404 for each; no file content outside public/	Sec	P1	test/security/security.test.js
TC-121	Login rate limiting	RATE_LIMIT_LOGIN_MAX=10	11 logins in 60 s from one IP	11th → 429 RATE_LIMITED "Too many sign-in attempts — wait a minute", Retry-After: 60	Sec	P1	test/security/security.test.js
TC-122	Global rate limiting	RATE_LIMIT_MAX=300 (lower in test)	Exceed the per-IP budget (certificate verify costs 2)	429 with Retry-After = seconds to window reset; http_requests_total{status="429"}	Sec	P1	test/security/security.test.js
TC-123	SQL injection in query filters	Postgres store	GET /api/leads?region=' OR '1'='1,?tier=hot'--, GET /api/audit?entityId=x'%3B DROP TABLE audit_log--	Region treated as a literal (0 rows, 200); tier → 400 enum; audit → 200 empty; tables intact (bind parameters)	PG / Sec	P1	test/pg/postgres.test.js, test/security/security.test.js
TC-124	SQL injection via path and sort	Postgres	GET /api/customers/1'%200R%201=1--; GET /api/leads?sort=score;DROP	404 Customer; 400 enum (sort ∈ score, expiry). Columns are never taken from input (assertColumns)	PG / Sec	P1	test/pg/postgres.test.js, test/security/security.test.js
TC-125	Security headers	NODE_ENV=production	Any request	CSP default-src 'self' with frame-ancestors 'none'; nosniff; X-Frame-Options: DENY; Referrer-Policy: no-referrer; HSTS in production only; no X-Powered-By; API Cache-Control: no-store	Sec	P1	test/security/security.test.js
TC-126	CORS allow-list	CORS_ORIGINS=https://console.tasco.vn	Request with Origin: https://evil.example	403 "Origin not allowed"; an allowed origin gets Access-Control-Allow-Origin echoed and Vary: Origin	Sec	P1	test/security/security.test.js
TC-127	Method not allowed	—	DELETE /api/leads	405 METHOD_NOT_ALLOWED	API	P3	test/api/api.test.js

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-128	Request ID propagation	—	Send X-Request-Id: abcd1234-ok; send X-Request-Id: <script>	First echoed; second replaced by a UUID; error bodies carry requestId; access log line has requestId, route, status, ms	API	P2	test/api/api.test.js
TC-129	Malformed percent-encoding (KI-11)	—	GET /api/customers/%E0%A4%A	400 VALIDATION_FAILED "Malformed path parameter" (KI-11 fixed); no unhandled error log	API	P3	test/api/api.test.js
TC-130	Idempotency-Key required	Customer quote	POST /api/customer/orders without the header; with abc (too short)	400 "Idempotency-Key header (8–100 chars) is required"	API	P1	test/api/api.test.js
TC-131	Health probes	Postgres store	GET /health/live; GET /health/ready; stop Postgres; GET /health/ready	live 200 {status:"ok"}; ready 200 {status:"ready", store:"postgres", db:true}; with the DB down 503 {status:"not_ready", db:false}; live still 200	PG	P1	test/api/api.test.js (live, ready); DB-down step manual (PREPROD)
TC-132	Metrics exposition	Traffic generated; METRICS_TOKEN set	GET /metrics without, then with Authorization: Bearer <token>	Without the token → 401. With it: text format 0.0.4 with http_requests_total, http_request_duration_seconds_bucket (to le="+Inf"), quotes_total, orders_completed_total, integration_calls_total, events_published_total, process_resident_memory_bytes	API	P2	test/api/api.test.js
TC-133	OpenAPI contract completeness	—	GET /api/openapi.json	openapi:"3.1.0"; one operation per route (80); security per audience (partnerApiKey, bearerAuth, public []); Idempotency-Key required on both order routes; bodies additionalProperties:false; generated spec equals the committed docs/api/openapi.json	API	P1	test/api/api.test.js
TC-134	Demo seed refused outside demo mode (KI-01)	DEMO_MODE=false, Postgres	npm run job -- seed	Exits non-zero with "only allowed with DEMO_MODE=true"; no users created (KI-01 fixed)	Sec	P1	Manual (release checklist)

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-135	Voice campaign respects contact policy (KI-09)	Hot leads with call consent; time 21:00 ICT; one lead already called twice this week	POST /api/voice/campaign {limit:5}	At 21:00: called:0, skipped "outside allowed contact hours". At 10:00: twice-called lead skipped "weekly call cap reached"; each call recorded as a marketing contact (KI-09 fixed)	Int	P1	test/integration/governance.test.js, test/api/api.test.js

14. Non-functional, resilience and DR

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-136	Peak-hour mixed load	PERF env, 6M profiles	Run PERF-S1 (Performance plan)	p95 per endpoint within SLO; 5xx < 0.1 %; CPU < 70 % at target RPS	NFT	P1	test/perf/load.js
TC-137	Volume: 6M profiles initial load	Empty PERF DB	PERF-S7	Completes within the load window; counts reconcile (TC-112 method)	NFT	P1	test/perf/load.js + ingest job
TC-138	Soak 12 h	PERF env	PERF-S11	RSS slope < 5 %/h after warm-up; no pool exhaustion; error rate flat	NFT	P2	test/perf/load.js
TC-139	Stress to failure	PERF env	PERF-S10	Degrades with 429/503, never corrupts data; recovers to SLO within 5 min after load drops	NFT	P2	test/perf/load.js
TC-140	Circuit breaker state machine	Unit	5 consecutive failed exec calls; wait resetMs; one success	closed → open (short-circuit + metric) → half_open → closed (log "circuit closed"); a 4xx (non-retryable, except 429) does not count toward opening	Unit	P1	test/unit/platform.test.js
TC-141	Database failover	PREPROD HA Postgres	Trigger primary failover during load	Readiness 503 during the switch; recovery without restart; no lost committed orders; RTO ≤ 2 min	NFT	P1	Manual (DR drill DR-T2)
TC-142	Pod loss under load	k8s with PDB and HPA	Delete 1 of 3 pods at peak	No client-visible 5xx beyond retried in-flight requests; HPA restores replicas	NFT	P2	Manual (chaos drill)
TC-143	Restore from PITR	PREPROD	Restore to T-10 min into a new instance; point the app at it	Data matches up to the target time; GET /api/audit/verify ok; RPO ≤ 5 min demonstrated	NFT	P1	Manual (DR drill DR-T1)

15. Accessibility and localisation

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-144	Automated accessibility scan	Front-end deployed	axe-core on every page, light and dark, vi and en	0 serious or critical violations	NFT	P1	CI a11y job (UX workstream)

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-145	Screen-reader one-tap renewal	VoiceOver iOS + TalkBack Android	Open the renewal link → confirm → pay → certificate	Every control has an accessible name in Vietnamese; payment result announced; certificate QR has a text alternative (cert no.)	UAT	P1	Manual
TC-146	Keyboard-only staff console	NVDA + Firefox	Leads → Customer 360 → quote → order; handoff claim	Every action reachable; visible focus not obscured (WCAG 2.4.11); no keyboard trap	UAT	P2	Manual
TC-147	Vietnamese template rendering	Active content.messages	Render every template with a fixture	No unresolved <code>{{...}}</code> ; date dd/mm/yyyy; premium vi-VN with đ; the link is the signed /app/?r= form	Unit	P1	test/unit/rulesDomain.test.js
TC-148	English gloss for staff	Voice transcript	GET /api/voice/sessions/:id	Each bot line has text (vi) and gloss (en)	API	P3	test/api/api.test.js
TC-149	SMS length and diacritics	SMS brandname rules	Render the first_reminder, urgent_reminder and lapsed_notice SMS	Within the agreed segment count (UCS-2 70 chars/segment) or the approved unaccented variant	SIT	P2	Manual

16. SIT with VETC, TASCO and Zalo

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-150	Zalo ZNS template delivery	Templates approved by Zalo; OA test account	Trigger first_reminder and purchase_confirmation	Delivered with correct parameter mapping; providerMessageId stored; delivery receipt correlated	SIT	P1	Manual
TC-151	VETC SSO token exchange	VETC identity UAT	Exchange a valid, an expired and a foreign-audience token at POST /api/customer/session	Valid → customer token; others → 401 "Link invalid or expired"	SIT	P1	Manual → test/api contract stub
TC-152	Wallet debit idempotency and refund	VETC wallet UAT test wallets	Debit with the same idempotency key twice; force a client timeout then retry; refund	One capture; same transactionId; refund reflected in the wallet	SIT	P1	Manual
TC-153	TASCO core issuance	TASCO core UAT	Issue TNDs car, motorbike, MOTOR_PD, PA_SEAT	Policy and certificate numbers returned; the certificate URL opens /verify/<certNo>	SIT	P1	Manual
TC-154	Voice vendor integration	Vendor SIP test trunk; test SIM	Place a campaign call; speak the plate; opt out	ASR turns reach the dialogue; plate-first verification works on real speech; the opt-out persists	SIT	P1	Manual
TC-155	Settlement reconciliation	One day of SIT orders	Compare orders with the VETC settlement file and the TASCO issuance report	Zero unexplained differences; differences raised to RB-11	SIT	P1	Manual (KI-18)

17. Additional cases (assisted sales and review findings)

Staff never take payment: there is no staff order route. Telesales and supervisors create a quote (`POST /api/quotes`) and send it to the customer's VETC app or Zalo with `POST /api/quotes/:id/send` ; the customer sees it in `GET /api/customer/quotes` and pays in the app with `POST /api/customer/orders` (with an `Idempotency-Key`). Partner orders are partner-collected: no VETC wallet debit, `paymentRef` starts with `PARTNER-` , and the premium is remitted to TASCO under the partner agreement and commission statement.

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-156	Staff can never debit a customer wallet	Open quote; staff principal (agent.hn)	Call sales.purchase as staff (the service layer; no staff order route exists)	403 "Only the customer can confirm payment, inside the VETC app"; no debit; order payment_failed recorded; quote released	Int	P1	test/integration/sales.test.js
TC-157	Assisted sale: send the quote, customer pays in the app	agent.hn; HN customer reachable on app push	POST /api/quotes, then /send; customer GET /api/customer/quotes, then POST /api/customer/orders	Service message quote_ready (marketing:false) on each reachable channel; audit quote.sent_to_customer; quote listed for the customer until expiry; paid once; resending a quote that is not open → 422	API	P1	test/api/api.test.js
TC-158	Region check before side effects on quote send (KI-32)	agent.hn; quote for an HCM customer	POST /api/quotes/:id/send	403; quote not marked sent; no quote.sent_to_customer audit; no message (KI-32 fixed)	Sec	P3	Manual (UAT regression)
TC-159	Production refuses to run without a database (KI-28)	NODE_ENV=production, secrets set, no DATABASE_URL	Load the configuration / start the server	Fatal startup error "DATABASE_URL is required in production" (KI-28 fixed)	Unit	P1	test/unit/platform.test.js
TC-160	Replay of a failed order (KI-31)	Customer order failed (payment or issuance)	Re-send with the same Idempotency-Key; then with a new key	409 CONFLICT "A previous attempt with this Idempotency-Key ended as ... — retry with a new key"; new key → completed (KI-31 fixed)	Int	P2	test/integration/sales.test.js
TC-161	Partner order settlement	Partner key; partner quote	POST /api/partner/v1/orders	Order completed; paymentRef PARTNER-<partnerId>-<orderId>; no wallet call (integration_calls_total{integration="vetc-wallet"} unchanged); commission lines capped	API	P1	test/api/api.test.js
TC-162	Time override cannot bypass the contact window (KI-33)	DEMO_MODE=false; real time 21:00 ICT	POST /api/voice/campaign {at:"<today>T03:00:00Z"}; POST /api/journeys/run {at:"...T03:00:00Z"}	at and date ignored; the real clock applies, so no marketing calls or messages go out (KI-33 fixed)	Sec	P1	Manual (UAT regression)
TC-163	Physical damage needs an inspection before payment	Customer quote with MOTOR_PD (requiresInspection:true)	Customer pays; staff POST /api/quotes/:id/inspection {passed:true, evidence}; customer pays with a new key	First → 422 "Physical damage cover needs a vehicle inspection first ..."; audit quote.inspection_recorded; then 200 completed	API	P1	test/api/api.test.js

ID	Objective	Preconditions	Steps	Expected result	Type	Pri	Automation
TC-164	Claim detail for claims handlers	claims user	GET /api/claims/:id; unknown id	200 with history; 404 "Claim not found"; other roles → 403	API	P3	test/api/api.test.js

18. Traceability summary

Requirement area (from the project plan)	Test cases
Data foundation and identity (S1)	TC-001–TC-040, TC-108–TC-112
Scoring, journeys and messaging (S2)	TC-041–TC-063, TC-147, TC-150
Purchase and voice (S3)	TC-064–TC-080, TC-145, TC-151–TC-154, TC-156–TC-157, TC-160, TC-163
Governance, partners, claims, operations (S4)	TC-081–TC-107, TC-113–TC-116, TC-155, TC-161, TC-164
Platform security and NFRs	TC-117–TC-144, TC-158, TC-159, TC-162

User-story level traceability (FR → story → scenario → automated test) is in the *Functional Test Cases*

sheet of the results workbook and in the Requirements Traceability Matrix (docs/business/05-requirements-traceability-matrix.pdf).